

Case Study 1: Clearview AI

Read the following article: [Clearview AI's massive fine for GDPR violations — and what it means](#)

Clearview AI argued that because they only scraped photos that were "already public" on social media, they didn't need anyone's permission. Explain why the Dutch DPA ruled that Clearview violated the rights of individuals. Specifically, how does a "database of faces" make it impossible for a person to exercise their Right to Erasure (Right to be Forgotten)?

The Dutch DPA ruled that Clearview violated the rights of individuals on a GDPR principle: that a photo appearing on social media does not constitute consent for that image to be harvested, processed into biometric data, and sold to third parties. GDPR states that if you collect and store any personal data about any EU resident, you must have their permission and treat it carefully to ensure it is secure. Posting a photo online is a limited act that does not extend authorization to any entity that wants to exploit it commercially.

The "database of faces" structure is what makes the Right to Erasure unenforceable. Clearview's platform analyzes images and assigns a unique biometric code to each face, meaning a person's identity is no longer tied to a single photo but to a mathematical signature produced from potentially thousands of images. Even if an individual successfully demands deletion of their photos, the mathematical biometric signature can persist independently of the source images.

The Right to Erasure assumes a person can identify what data exists and request its deletion but due to the signature, a specific photo cannot be requested to be deleted. GDPR requires that individuals be informed about what their data will be used for and be provided a way to access it upon request, but Clearview collected data in private, without notification. An user cannot exercise a right they don't know they need to invoke and by the time they do, their biometric identity has already been encoded, distributed to law enforcement clients, and potentially cached across multiple systems far beyond any single deletion request.

Case Study 2: Uber

Read the following article: [Uber Data Breach](#)

Uber's security team paid hackers \$100,000 via a private "Bug Bounty" program and had them sign NDAs to keep the breach secret. What does the \$148 million settlement suggest about Uber's use of their Bug Bounty program in this case?

The \$148 million settlement makes it clear that regulators viewed Uber's Bug Bounty payment not as a legitimate security practice, but as a deliberate mechanism to obstruct legal obligations. The payment was disguised as a reward for discovering a security vulnerability and in turn landed Uber's former CSO in criminal conviction. The settlement shows that using a Bug Bounty program to funnel hush money to attackers crosses from security practice into criminal obstruction.

The main legal problem was not the payment itself but the concealment it enabled. Uber agreed to a \$148 million settlement with all 50 states and the District of Columbia for failing to report the breach in a timely manner. Simply, regulators were not simply penalizing Uber for being breached but for the active choice to hide it. The Bug Bounty program was the vessel for that concealment, allowing Uber to launder a ransom payment into something that looked, on paper, like routine vulnerability disclosure.

The scale of the financial penalty reinforces this interpretation. Bug bounties are only for bugs and disguising a ransom payment as a bug bounty is unethical and illegal. This settlement codifies that principle at a national level. A legitimate Bug Bounty program operates transparently and is designed to surface vulnerabilities so they can be remediated and disclosed. Uber's use inverted that purpose entirely, where it was designed to suppress disclosure and buy silence, which is precisely what the \$148 million penalized.

Case Study 3: Argon medical

Read the following article: [American company fined 2.5 million NOK for failure to notify the Data Protection Authority within 72 hours](#)

Argon Medical argued they were waiting for a complete forensic report before notifying authorities. Based on this case, why and how is it legally dangerous for a company to wait for a complete forensic analysis before notifying regulators? The Argon Medical case exposes a fundamental misunderstanding that many companies share: that notification obligations only arise once you have complete information about a breach. The Norwegian Data Protection Authority rejected this interpretation entirely.

The Norwegian Data Protection Authority concluded that the 72 hour period starts when a company becomes aware that a data breach has occurred, and not when the business has a full overview of the breach. Argon discovered that European employees were affected on July 19, 2021, but did not notify until September 24, 2021, 67 days later. The argument was that they first had sufficient information regarding the data breach when they notified in September and therefore notified within the 72 hour deadline, but the Norwegian DPA disagreed.

The misunderstanding shows the danger of waiting for forensic completion runs deeper than just missing the deadline. Regulators will impose higher fines when delays are unjustified since they assess the process not the outcome. Also, the Norwegian DPA emphasized that the company had not provided precise information in its correspondence, and that it was only through a careful examination of the notification that the authority discovered the 72 hour deadline had been breached. This means the delay itself, and the insufficient communication surrounding it, both resulted in the legal exposure.

The correct approach under GDPR is iterative disclosure where if the company does not have the full overview within the deadline, it must be notified successively, as the business receives more information. Waiting for a complete forensic report is not a valid legal defense but a violation itself. Hence, a company's procedure that conditions notification on a "full overview" is, by design, not compliant with GDPR.

Case Study 4: H&M

Read the following article: [H&M fined €35.3 Million for violation of the GDPR](#)

H&M managers recorded personal details about employees' health (symptoms and diagnoses) and family lives, which were then stored on a shared drive accessible to dozens of other managers.

Even if a company is not a healthcare provider, why does documenting "medical symptoms" create such an extreme legal risk? What else stands out to you about this case?

Documenting employee medical symptoms creates an extreme legal risk as seen in GDPR's special category framework. Health data is not treated as ordinary personal data but carries the highest tier of protection regardless of what industry you're in. In the employment sector, processing of sensitive data is only allowed if it is authorized by law and necessary for carrying out obligations related to employment, social security, and social protection law. H&M's "Welcome Back Talk" program did not meet that bar since recording symptom details and diagnoses went beyond what any return to work process requires, making the collection unlawful, not just in how it was stored.

According to the EDPB, the combination of collecting details about employees' private lives and the recording of their activities led to a particularly intensive encroachment on employees' civil rights. This combination amplifies the legal risk since health data alone is serious but it combined with religious beliefs, family circumstances, and personal leave details, mixes every violation.

What stands out most in this case is how the breach was discovered. It was stated that in October 2019, due to a technical error, the data on the company's network drive became accessible to everyone in the company for a few hours, which drew regulatory attention and resulted in H&M handing over 60 GB of personal data. It was only due to an accidental error that the entire surveillance architecture was exposed and the fact that it wasn't due to a whistleblower or external audit was mind boggling. This showed that unauthorized internal data practices often go undetected mostly because access controls are designed to protect against external threats, not against the organization itself.